

Advisory - Google Chrome and Chromium Based Browsers Zero-Day Vulnerability (CVE-2025-6558)

Severity – High

CVSS – 8.8

CWE – Improper Input Validation

Executive Summary

Google has released security updates to address CVE-2025-6558, a high-severity zero-day vulnerability affecting Google Chrome and Chromium-based browsers. The vulnerability was actively exploited before the availability of a security patch, creating a significant risk to organizations and individual users.

The vulnerability resides within Chrome's graphics processing components (ANGLE and GPU). An attacker can exploit the flaw by convincing a user to visit a specially crafted malicious webpage. Successful exploitation may allow the attacker to bypass Chrome's browser sandbox, potentially leading to arbitrary code execution as part of a broader exploit chain, enabling malware deployment, data theft, unauthorized system access, or further compromise of the affected device.

Google released security updates to remediate this vulnerability on July 15, 2025. Organizations are strongly advised to ensure that all Google Chrome and Chromium-based browsers are updated to the latest vendor-supported versions to protect against known exploitation.

Vulnerability Description

[CVE-2025-6558](#) is a high-severity insufficient input validation vulnerability (CWE-20) affecting the ANGLE (Almost Native Graphics Layer Engine) and GPU components of Google Chrome. The vulnerability affects Google Chrome versions prior to 138.0.7204.157/.158 and may also impact other Chromium-based browsers until they incorporate the corresponding Chromium security updates.

The vulnerability exists within Chrome's graphics processing pipeline, specifically in the ANGLE component, which acts as a translation layer between Chrome's rendering engine and the operating system's graphics drivers. ANGLE converts graphics requests generated by web technologies such as WebGL into platform-specific graphics API calls that are processed by the GPU.

An attacker can exploit this vulnerability by hosting a specially crafted malicious webpage and convincing a user to visit it through phishing emails, malicious advertisements, compromised websites, or other social engineering techniques. When the page is loaded, Chrome's renderer process parses the HTML, executes JavaScript, and processes graphics-related requests. These requests are forwarded through ANGLE to the GPU process and ultimately to the system's graphics drivers.

Due to improper validation of untrusted input, specially crafted graphics operations can bypass expected security checks, allowing an attacker to perform a browser sandbox escape. This enables code execution outside the browser's restricted rendering environment and, when combined with additional vulnerabilities, may lead to arbitrary code execution, malware deployment, credential theft, unauthorized access, or further compromise of the affected system.

Attack Vector

The attack can be launched remotely over the network through specially crafted HTML pages that exploit the improper input handling.

```
// Example exploitation code (sanitized)
element->ValidateGPUInput(
    untrustedInput->GetWidth(),
    untrustedInput->GetHeight(),
    untrustedInput->GetFormat()
);
```

Attack Flow

- Attacker creates a malicious webpage containing crafted HTML, JavaScript, and WebGL content
- Delivers it through phishing, malicious ads, redirects, or a compromised website
- Victim opens the page in a vulnerable Chrome browser
- Chrome's renderer processes the webpage and its graphics instructions
- The commands are passed to ANGLE for translation and validation
- CVE-2025-6558 allows an unsafe graphics sequence to bypass validation
- The malformed request reaches the GPU process or graphics driver
- Memory corruption occurs, allowing the attacker to escape the browser sandbox
- Additional exploits may provide higher privileges
- Malware deployment, credential theft, data loss, or wider system compromise may follow

Potential Impact

Successful exploitation of CVE-2025-6558 may allow a remote, unauthenticated attacker to bypass Chrome's browser sandbox by directing a user to a specially crafted malicious webpage. This could enable attacker-controlled code to execute outside the restricted renderer environment and provide access to more sensitive browser or system resources.

When combined with additional browser, driver, or operating-system vulnerabilities, the flaw may lead to:

- Arbitrary code execution
- Malware or spyware deployment
- Credential and browser-session theft
- Unauthorized access to sensitive data
- Data modification or deletion
- Command-and-control communication
- Browser or system instability and service disruption
- Further privilege escalation and endpoint compromise

Recommended Action

1. Identify affected systems

Creating an inventory of all endpoints running:

- Google Chrome
- Microsoft Edge
- Brave, Opera, Vivaldi, or other Chromium-based browsers
- Chrome on Windows, macOS, Linux, Android, and ChromeOS

2. Check the installed Chrome version

Users can verify the version by navigating to :

Chrome menu (⋮) → Help → About Google Chrome

Minimum Fixed Chrome Versions:

Windows ----- 138.0.7204.157 or 138.0.7204.158

MacOS----- 138.0.7204.157 or 138.0.7204.158

Linux-----138.0.7204.157

Since these versions are now outdated, systems should be upgraded to the latest stable, vendor-supported browser version, not merely to version 138.

3. Deploy the update immediately

Chrome menu (⋮)

Help → About Google Chrome → Allow the update to download →
Select Relaunch

The browser must be completely relaunched because downloading an update alone does not activate the patched browser binaries.

4. Update the operating system and graphics stack

Because the vulnerability involves the graphics-processing path, organizations should also install available updates for:

- Operating systems
- GPU drivers
- Android security updates
- Device firmware
- ARM Mali graphics components where applicable.

References

1.Chrome Issues - <https://issues.chromium.org/issues/427162086>

2.Google Threat Intelligence : 2025 Zero Days in Review
<https://cloud.google.com/blog/topics/threat-intelligence/2025-zero-day-review>

3.Google Source Angle.git Website -
<https://chromium.googlesource.com/angle/angle.git/+2f8193ecfe1ed464374ae56235cfdc112343f9c3>

4.Nist CVE 2025-6558 - <https://nvd.nist.gov/vuln/detail/CVE-2025-6558>

5.SOC PRIME ARTICLE -
<https://socprime.com/blog/cve-2025-6558-google-chrome-vulnerability/>

6. SecPod Article -
<https://www.secpod.com/learn/security-research/joint-threat-to-safari-and-chrome-users-patch-cve-2025-6558-now>

7. Sentinel Article -
<https://www.sentinelone.com/vulnerability-database/cve-2025-6558/>